Every Sector Has a Framework. None Has the Architecture.

A common structural gap runs through every U.S. critical infrastructure cybersecurity framework: each one mandates security outcomes without specifying the architecture required to achieve them. The same missing layer appears in HIPAA, NERC CIP, TSA Pipeline Security Directives, AWIA, USCG NVIC 01-20, ISA/IEC 62443, and NIST SP 800-82. That missing layer is a formally governed cloud boundary and AI governance specification for OT environments. The table below maps each framework against the gap. The final column shows how a single cross-sector architectural standard closes it.

Framework / Directive	Sector(s)	What It Mandates	What It Leaves Unspecified	Purdue 2.0 Gap Closed
HIPAA Security Rule (2026 update)	Healthcare	Risk assessment; penetration testing; network segmentation; MFA; encryption — but only for systems handling ePHI	No technical architecture specification. No definition of how to segment. No cloud boundary governance. Silent on AI systems as security principals.	Level 6 Cloud Tier defines the technical boundary HIPAA assumes exists between on-premises clinical OT and cloud-hosted EHR, AI inference, and vendor remote access. AI Governance Taxonomy classifies clinical AI as a formal security principal.
NERC CIP (CIP-002 through CIP-014)	Electric Grid / Bulk Power System	Electronic Security Perimeter (ESP) definition; access controls; patch management; incident response; supply chain risk (CIP-013) for bulk electric assets	No formal ESP specification for cloud-hosted systems interacting with BES. No DERMS, cloud historian, or demand response aggregator governance. No AI governance framework for grid optimization AI.	Level 6 formally extends the ESP concept to cloud-hosted grid management platforms, demand response APIs, and AI-driven load forecasting — closing the boundary NERC CIP defines only for on-premises assets.
TSA Pipeline Security Directives (SD-02C and successors)	Oil and Gas / Pipeline	Network segmentation between IT and OT; access control; patching; continuous monitoring; incident response — most prescriptive pipeline OT standard post-Colonial Pipeline	No cloud boundary specification for cloud-hosted pipeline monitoring, remote SCADA access, or AI-driven integrity management. No formal governance for vendor remote access portals (the Colonial Pipeline attack vector).	Level 6 governs remote access portals (the exact Colonial Pipeline entry vector) and cloud pipeline monitoring as formal conduits with ZTNA and MFA requirements. Directly addresses the gap the directives were written in response to but did not close.
AWIA 2018 / EPA Risk Assessment Requirements	Water / Wastewater	Risk and resilience assessments every 5 years; emergency response plans — no mandatory technical cybersecurity controls for most systems	No mandatory OT security standard. No segmentation requirement. No cloud governance. No specification for internet-facing PLCs (the current Iranian attack vector). No AI governance.	Level 0 zone specification directly addresses internet-exposed PLCs targeted in the July 2026 Iranian campaign across 7 states. Level 6 governs the remote access interfaces that give attackers access to water treatment control systems with no current formal governance.
USCG NVIC 01-20 / MTS Cybersecurity Final Rule	Maritime / Port Facilities	Cyber risk assessments in Facility Security Plans; references NIST SP 800-82; requires IT/OT network identification; incident reporting via NVIC 02-24. Most operationally specific sector guidance.	Voluntary guidance framework (NVIC 01-20); Final Rule adds minimum performance requirements but still no cloud boundary specification. No formal governance for satellite connectivity, cloud port	Level 6 addresses satellite and cloud connectivity as ungoverned OT interfaces in maritime environments. AI Governance Taxonomy applies to AI cargo, logistics, and vessel monitoring systems that interact with port OT infrastructure outside any existing framework specification.

Framework / Directive	Sector(s)	What It Mandates	What It Leaves Unspecified	Purdue 2.0 Gap Closed
			management systems, or AI cargo optimization platforms.	
ISA/IEC 62443	All OT Sectors (International Standard)	Zones and conduits; security levels (SL-1 through SL-4); component, system, and program requirements — the most technically detailed OT security standard available	Written before cloud-hosted OT management was operationally common. No Zone/Conduit specification for cloud systems. No security level assignment methodology for AI inference engines or agentic AI as security principals.	Level 6 is proposed as a formal ISA/IEC 62443 zone requiring security level assignment and conduit specification — using the existing IEC 62443 governance model and extending it to the cloud boundary every sector is already crossing without governance.
PCI DSS 4.0 / 4.0.1 (Industry contractual standard — see note)	Financial Services / Any Payment Processing	Network segmentation of Cardholder Data Environment (CDE); Shared Responsibility Model (SRM) documentation for cloud deployments; MFA on all CDE access; continuous monitoring (not point-in-time); penetration testing of cloud boundaries; annual QSA validation. Most implementation-specific private-sector standard available.	SRM delegates cloud boundary definition to bilateral CSP contracts, not a formal security zone specification. No technical architecture requirement for the cloud interface — only responsibility allocation. No governance for AI systems that access or process cardholder data in the CDE. Completely silent on agentic AI as a security principal in payment environments.	Level 6 Cloud Tier provides the formal zone specification that SRM documentation assumes but does not define — treating every CSP connection as a governed conduit with explicit allow-listing and authentication requirements. AI Governance Taxonomy fills the complete absence of AI security principal governance in payment card environments.
NIST SP 800-82 Rev. 3	All OT Sectors (Federal Guidance)	Descriptive OT security guidance aligned with Purdue hierarchy; defense-in-depth; network segmentation; incident response; supply chain — comprehensive reference but descriptive, not prescriptive	No prescriptive architecture standard. References Purdue Model Levels 0-5 but provides no boundary architecture for cloud infrastructure interacting with OT. No AI governance framework. No Level 6 specification.	Purdue 2.0 is a natural extension of the NIST SP 800-82 conceptual framework — adding the prescriptive Level 6 architecture specification that SP 800-82 does not provide. A joint NIST/CISA/DOE development of this standard would formalize what SP 800-82 leaves descriptive.

Key Finding

Every framework in this table mandates that organizations protect their OT environments. None formally specifies the boundary between those environments and the cloud-hosted systems now integral to their operations. Colonial Pipeline entered through an unspecified remote access interface. Change Healthcare entered the same way. The July 2026 Iranian water utility attacks exploit PLCs exposed through unspecified internet interfaces. The architectural gap is not sector-specific. It is universal. And it is present in every compliance framework simultaneously.

Policy Recommendation

Direct NIST, in coordination with CISA, CESER, and sector-specific regulators, to develop a cross-sector OT Cloud Boundary Architecture Standard, analogous to what NIST SP 800-82 provided for ICS security, that formally specifies the Level 6 cloud boundary as a governable security zone and defines AI governance requirements for OT environments. This standard would serve as the architectural foundation every existing sector framework currently assumes exists but does not define, giving HIPAA, NERC CIP, TSA directives, AWIA, and the MTS Rule a common technical baseline to reference rather than requiring each sector to develop architecture guidance independently.

Note: PCI DSS is an industry contractual standard enforced through card brand agreements (Visa, Mastercard, AmEx), not a statutory regulatory framework. It is included because its reach across commercial transaction infrastructure — including payment systems adjacent to energy, pipeline, and maritime OT environments — makes the shared cloud/AI governance gap relevant to the cross-sector analysis. Its inclusion does not imply federal regulatory authority over payment card standards.

This brief accompanies: *Purdue 2.0: Extending the Purdue Enterprise Reference Architecture for Cloud Integration and AI Governance Across Critical Infrastructure OT Sectors* (Schramm, K., July 2026). Submitted to ONG-ISAC via CTI channel. Available on request.